



Advanced Internet of Things Technology

Week 6: IoT Security

TS. Huỳnh Văn Đăng

Department of Computer Networks

Faculty of Computer Networks and Communications

University of Information Technology, VNUHCM

Email: danghv@uit.edu.vn

February 2026

Lecture Overview — IoT Security



Motivation: Why IoT Security Matters

- Rapid growth of IoT devices across industries and daily life
- Integration of sensing, computing, and communication in physical environments
- Security failures can cause physical safety and privacy risks
- Large attack surface due to scale and heterogeneity

From IT Security to IoT Security

- Traditional IT assumes controlled environments and strong resources
- IoT systems operate with constrained hardware and intermittent connectivity
- Devices are often deployed in hostile or publicly accessible locations
- Long lifecycle creates persistent vulnerabilities

Lecture Structure



Main Topics Covered

- Part I: Why IoT Security is Different
- Part II: Threat Modelling and Attack Surfaces
- Part III: Protocols and Security Mechanisms
- Part IV: Hardware and Lifecycle Security

Case Study Integration

- MQTT security scenario used to connect theory with practice
- Realistic deployment vulnerabilities and mitigations
- Engineering trade-off discussion
- Preparation for advanced topics

Part I — Why IoT Security is Different

IoT System Characteristics



Resource Constraints

Limited CPU processing capability

Small memory capacity

Energy limitations (battery-powered devices)

Lightweight operating systems or firmware



Connectivity Challenges

Unreliable wireless links

Intermittent connectivity

Low data rates in some technologies

Mobility and dynamic network topology



Scale and Deployment

Massive number of distributed devices

Large geographical coverage

Difficult asset inventory and management

Diverse vendors and configurations

Physical Accessibility Risks

- Devices deployed in public or unattended environments
- Attackers may directly access hardware interfaces
- Environmental exposure increases failure probability
- Tampering detection often absent

Interaction with Physical World

- Sensors can be manipulated through environmental changes
- Actuators may cause physical consequences
- Safety risks exist beyond data confidentiality
- Physical compromise may bypass software protection

Technology Diversity

- Multiple communication protocols (BLE, Zigbee, Wi-Fi, LoRa, 5G)
- Different hardware architectures and chipsets
- Various operating systems and firmware stacks
- Interoperability challenges between vendors

Integration Complexity

- Interaction with cloud services and APIs
- Mobile applications and user interfaces
- Gateway translation across protocols
- Supply chain dependencies in hardware and software

Lifecycle Challenges in IoT



Long Device Lifetimes

- Devices may operate for years or decades
- Hardware replacement is costly or impractical
- Security mechanisms may become outdated
- Cryptographic algorithms may weaken over time

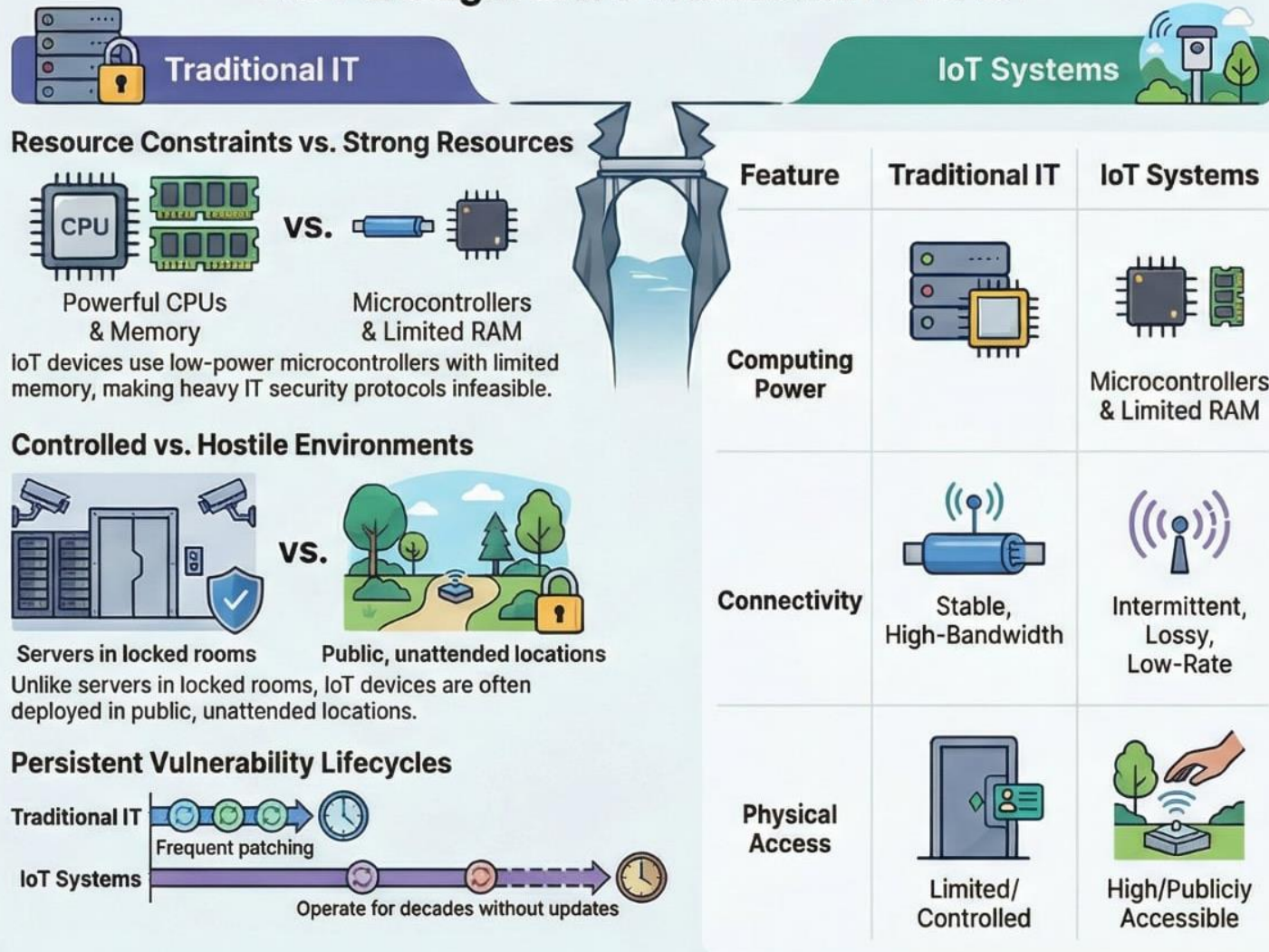
Update and Maintenance Difficulties

- Firmware update mechanisms may be limited
- Patch deployment may disrupt operations
- Some devices never receive updates
- Decommissioning creates residual risks

Traditional IT vs IoT Security



The Paradigm Shift: Traditional IT vs. IoT



Engineering a Secure IoT Ecosystem

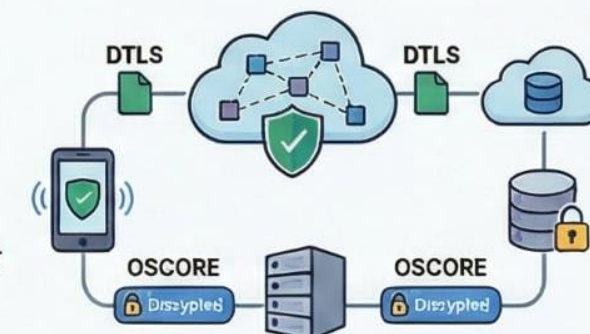


Proactive STRIDE Threat Modeling

Integrated flow-letted security measures. Identify Spoofing, Tampering, and Repudiation risks at the design stage to prioritize mitigations.

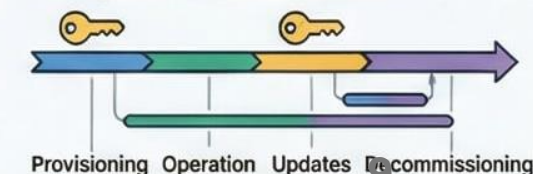
Optimized Communication Protocols

Use DTLS for lossy networks and OSCORE for end-to-end application-layer security across proxies.



Secure Onboarding & Lifecycle

Establish trusted identities via X.509 certificates or tokens to manage keys throughout the device lifetime.



Computing Capability

- Servers have powerful processors and memory
- IoT devices rely on microcontrollers
- Limited hardware acceleration for cryptography
- Processing overhead affects energy consumption

Security Implications

- Heavy security protocols may be infeasible
- Lightweight cryptography becomes necessary
- Performance–security trade-offs must be considered
- Energy consumption becomes part of threat model

Network Assumptions



Connectivity Models

- IT assumes stable and high-bandwidth connectivity
- IoT networks may be lossy and constrained
- Wireless interference impacts reliability
- Mobility introduces session disruption

Protocol Design Impact

- Security handshake costs must be reduced
- Session resumption becomes important
- Datagram-based protocols preferred in some scenarios
- Network latency affects authentication mechanisms

Asset Management Challenges

- IoT devices may lack central inventory tracking
- Device identity may be duplicated or unknown
- Monitoring endpoints is difficult
- Logging capability may be limited

Operational Security Impact

- Incident detection becomes harder
- Forensic investigation may be incomplete
- Automated management tools are required
- Security posture may degrade over time

Layered IoT Architecture

Device Layer

Sensors and actuators interacting with environment

Embedded firmware and microcontrollers

Local data processing capability

Network and Edge Layers

Gateways aggregate and forward data

Edge computing performs local analytics

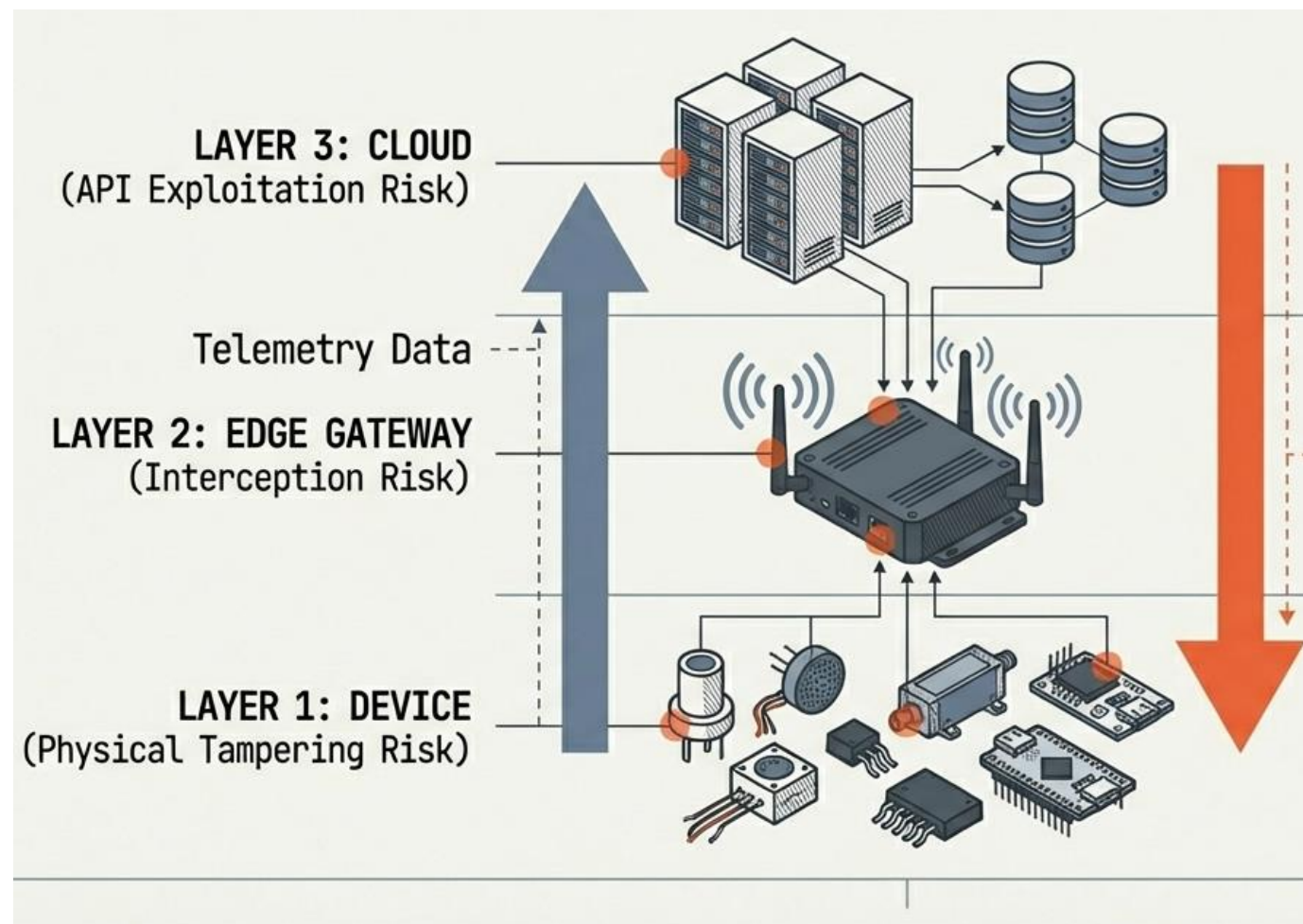
Local decision-making capabilities

Cloud and Application Layers

Data storage and analytics platforms

Application services and dashboards

User interfaces and mobile apps



Attack Propagation Across Layers

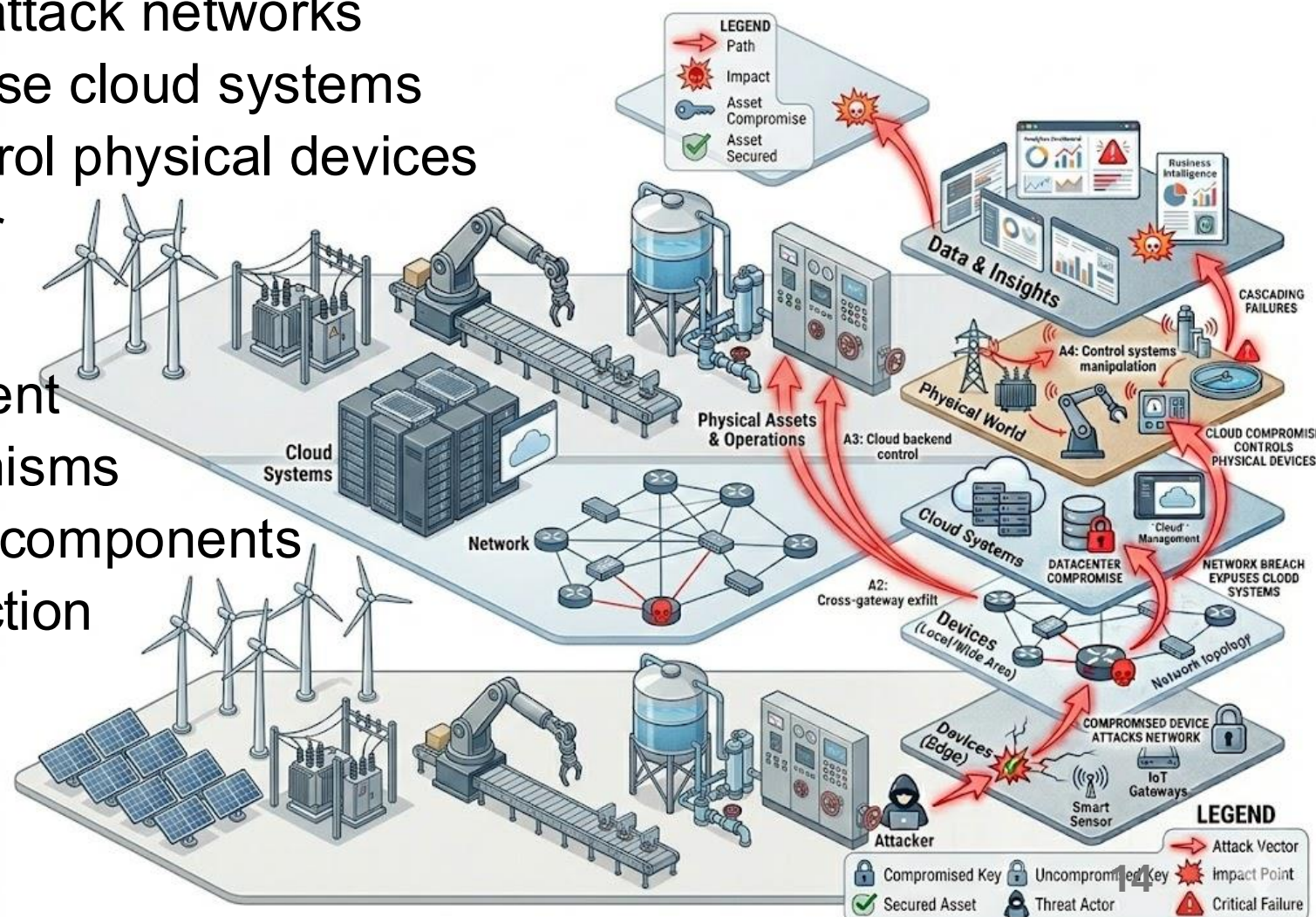


Cross-Layer Impact

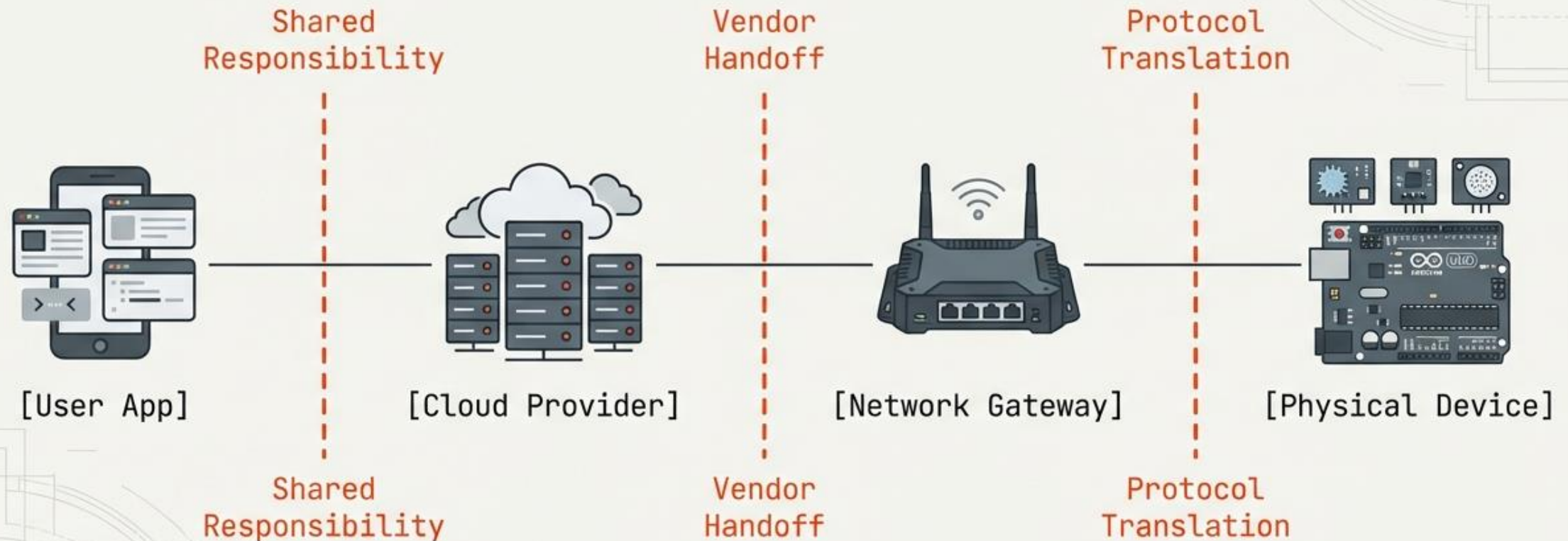
- Compromised devices may attack networks
- Network breaches may expose cloud systems
- Cloud compromise may control physical devices
- Cascading failures can occur

Risk Amplification Factors

- Large-scale device deployment
- Weak authentication mechanisms
- Poor segmentation between components
- Lack of monitoring and detection



Trust Boundaries and Administrative Domains



The Risk: Security breaks down at the seams. Misconfiguration at integration points—where control is handed off between vendors—is the primary vulnerability.

Part II — Threat Modelling and Attack Surfaces

Purpose of Threat Modelling



Security Planning Goals

- Identify assets and potential threats
- Understand attacker motivations
- Evaluate vulnerabilities before deployment
- Prioritise mitigation strategies

Engineering Benefits

- Supports secure architecture design
- Improves risk communication
- Guides resource allocation
- Enables proactive security decisions

Threat Modelling Methods

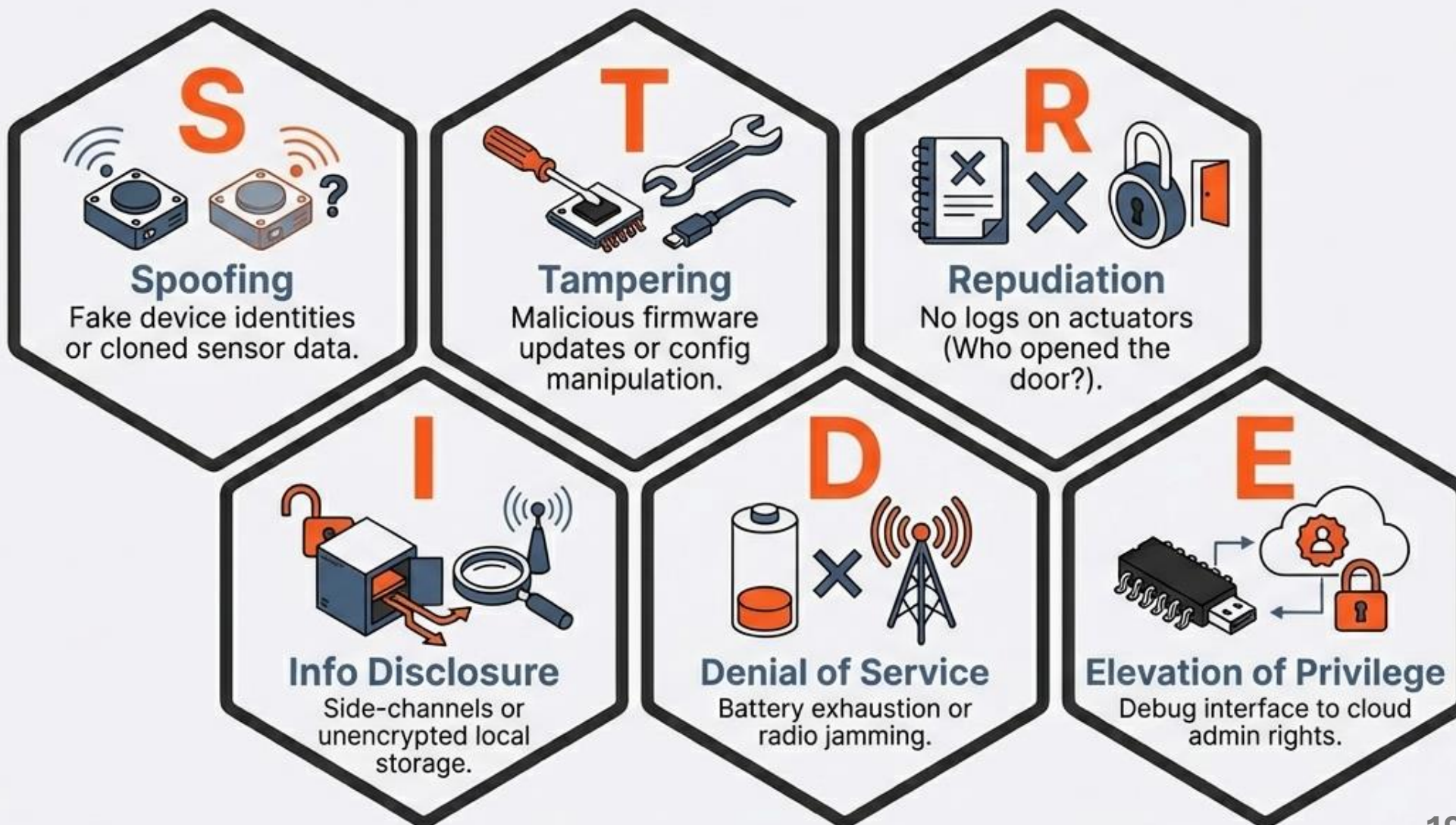


STRIDE Framework

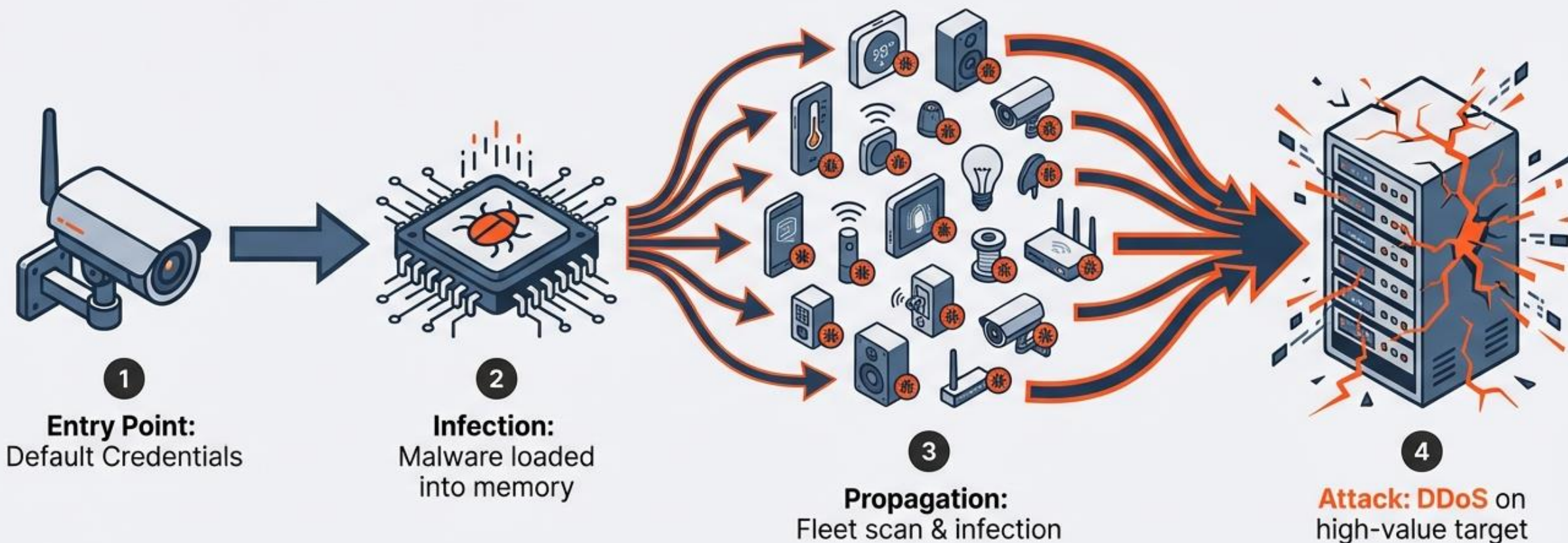
- Systematic threat categorisation approach
- Maps threats to system components
- Useful for architecture analysis
- Widely adopted in industry



Thinking Like an Attacker: STRIDE for IoT



Attack Propagation: The Botnet Effect



“Risk Amplification: Weak devices enable large-scale attacks.
Compromise propagates across systems.”

Part III — Protocols and Security Mechanisms

Security Layers in IoT Communication

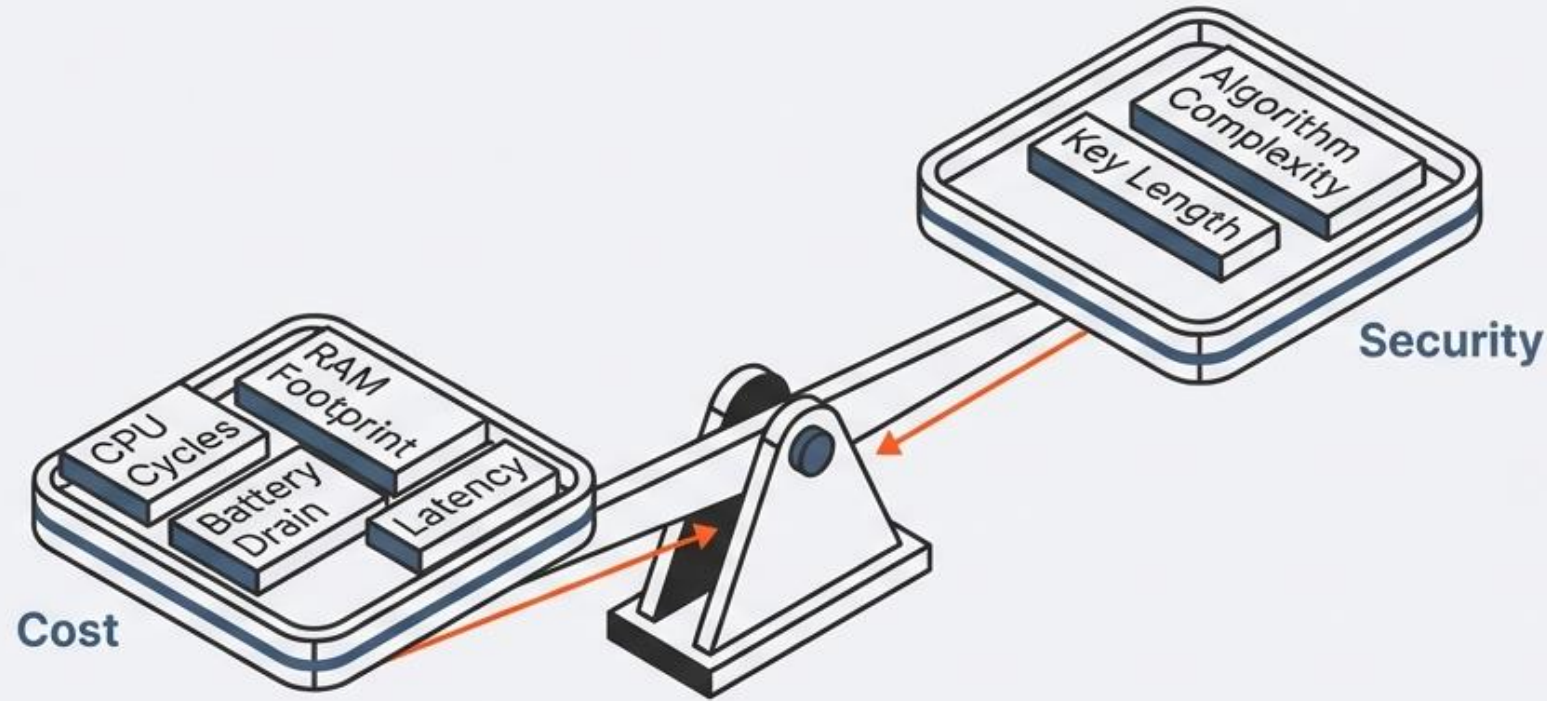
- Link-layer protection (e.g., IEEE 802.15.4 security)
- Transport-layer protection (TLS / DTLS)
- Application-layer protection (object security, tokens)
- End-to-end vs hop-by-hop security considerations

Design Trade-offs

- Security overhead vs device resource constraints
- Latency introduced by cryptographic handshakes
- Scalability across large device fleets
- Flexibility for heterogeneous deployments

The Cost of Math: Cryptography on a Budget

DIN Next LT Pro



Algorithm	IoT Suitability	Characteristics
RSA (Traditional IT)	Too Heavy	High computation & memory cost
ECC (Elliptic Curve)	IoT Standard	Efficient key exchange, lower energy
Symmetric (AES)	Fastest	Requires secure key distribution

Inter Energy consumption is part of the threat model. We choose algorithms that maximize protection per milliwatt.

TLS vs DTLS for IoT Systems



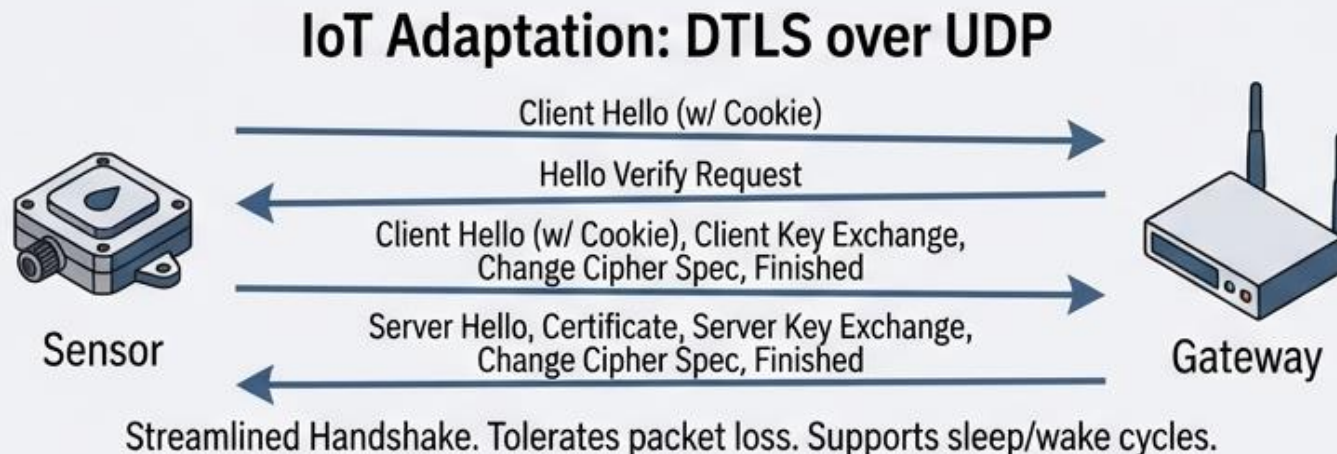
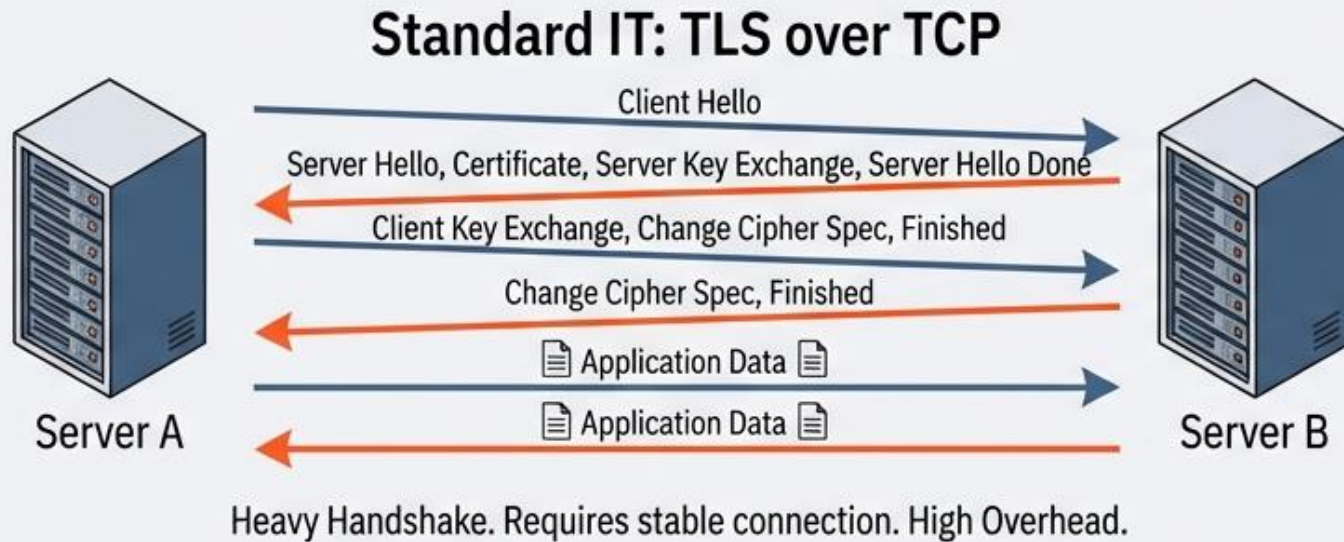
Transport Protocol Differences

- TLS operates over TCP with reliable delivery
- DTLS operates over UDP for constrained networks
- DTLS supports lossy and intermittent connectivity
- Datagram communication reduces overhead in some scenarios

Performance and Security Considerations

- Handshake complexity affects energy consumption
- Session resumption reduces communication overhead
- Connection ID supports mobility scenarios
- Cipher suite selection impacts efficiency

Transport Security: Adapting to Unreliable Networks



- Datagram-based: Tolerates intermittent connectivity
- Connection ID: Supports mobility (changing IP addresses)
- Session Resumption: Reduces wake-up costs

DTLS optimizes security for resource-constrained IoT devices operating in challenged network environments.

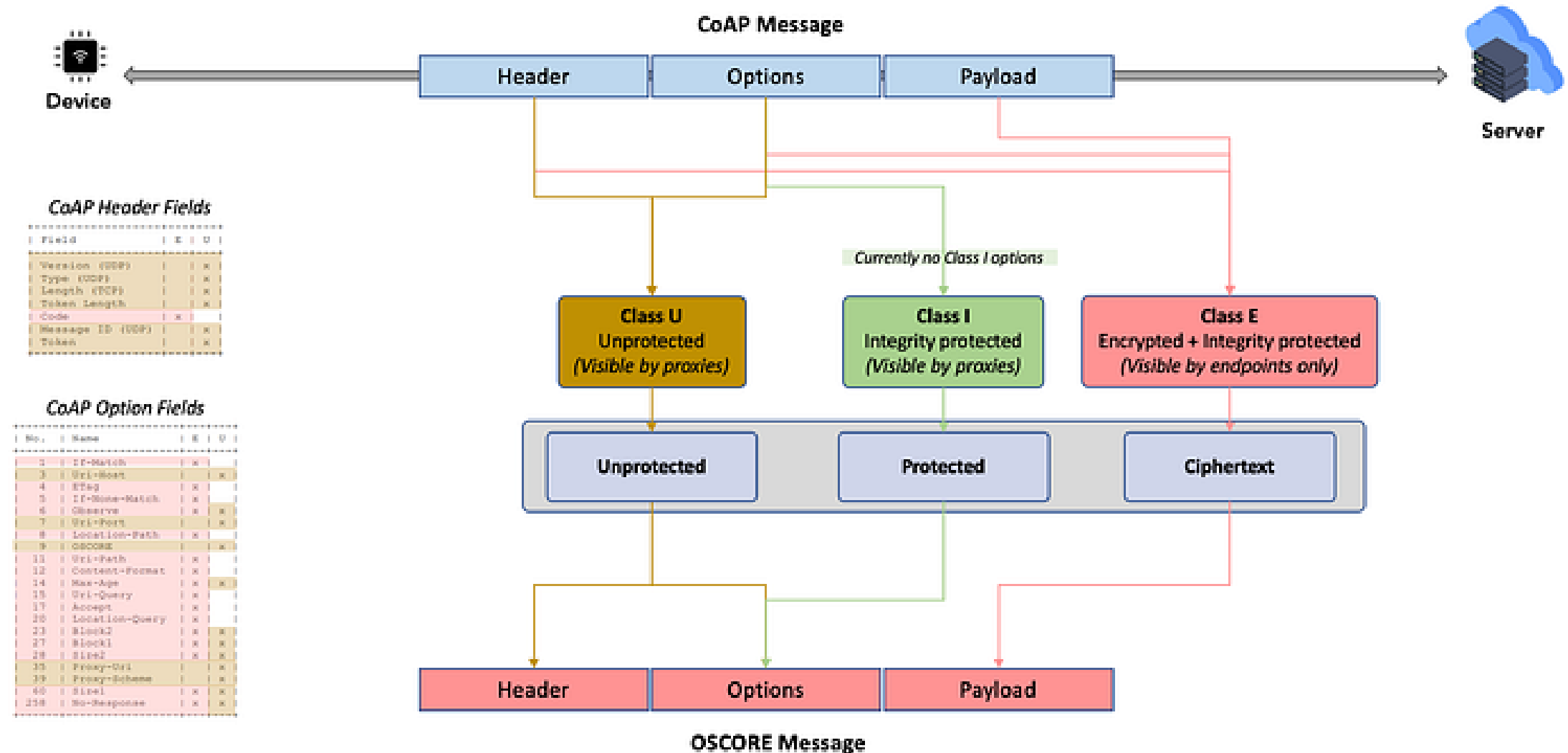
CoAP Fundamentals

- Lightweight REST-based protocol for constrained devices
- Designed to operate over UDP
- Supports asynchronous communication models
- Compatible with HTTP-like semantics

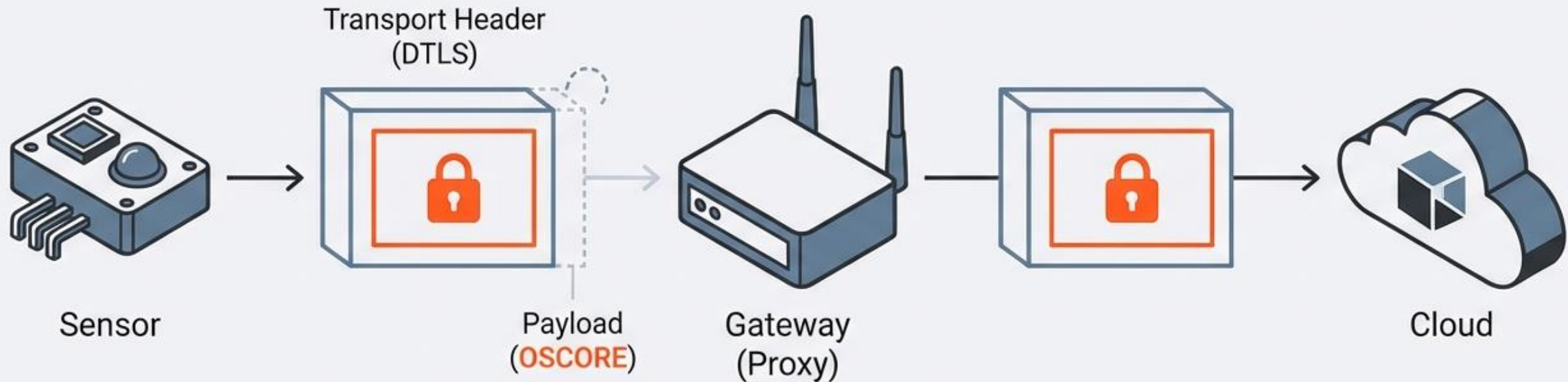
Security Mechanisms for CoAP

- DTLS for channel security
- OSCORE for object-level end-to-end security
- Protection across proxy environments
- Message integrity and confidentiality guarantees

OSCORE Message



Application Layer: CoAP and Object Security (**OSCORE**)



CoAP: Lightweight REST over UDP (Low overhead).

The Challenge: Transport encryption (DTLS) ends at the gateway.

The Solution (OSCORE): Encrypts the payload **end-to-end**. Only the final destination can decrypt.

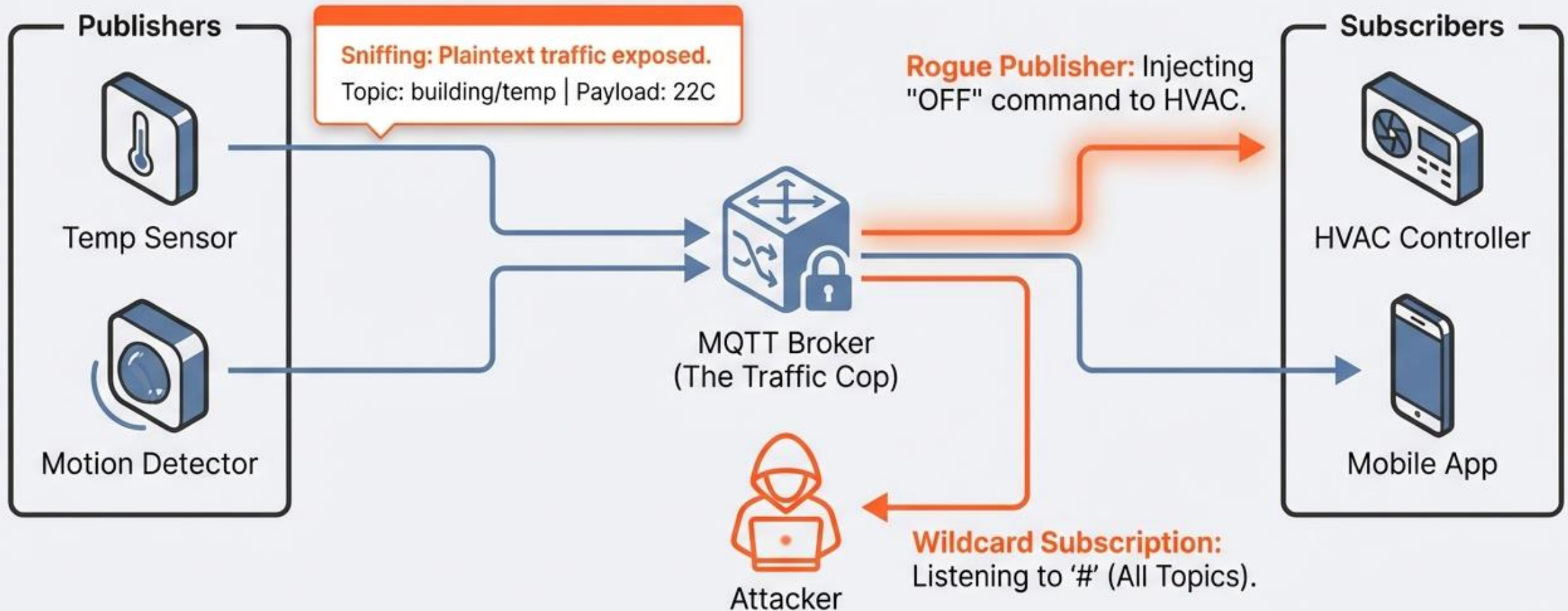
MQTT Communication Model

- Publish–subscribe messaging architecture
- Central broker mediates communication
- Topics organise logical data channels
- Asynchronous communication pattern

Security Components in MQTT

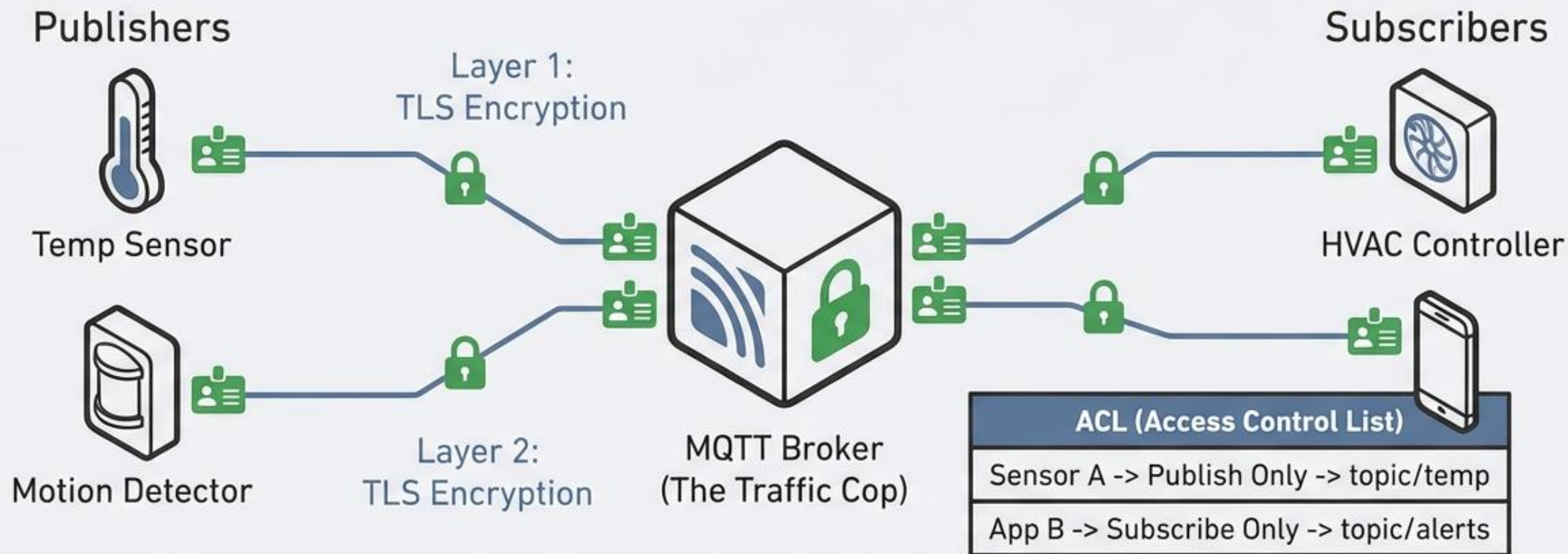
- Transport encryption using TLS
- Client authentication mechanisms
- Broker authorisation using access control lists
- Topic isolation and permissions

Scenario A: The Vulnerable Deployment in DIN Next LT Pro, Charcoal (#2C2C2C)



Root Causes: No Encryption, Weak Authentication, No Access Control Lists.

Scenario B: Defense in Depth



Result: Compromised devices are isolated. Traffic is encrypted.
Unauthorised commands rejected.

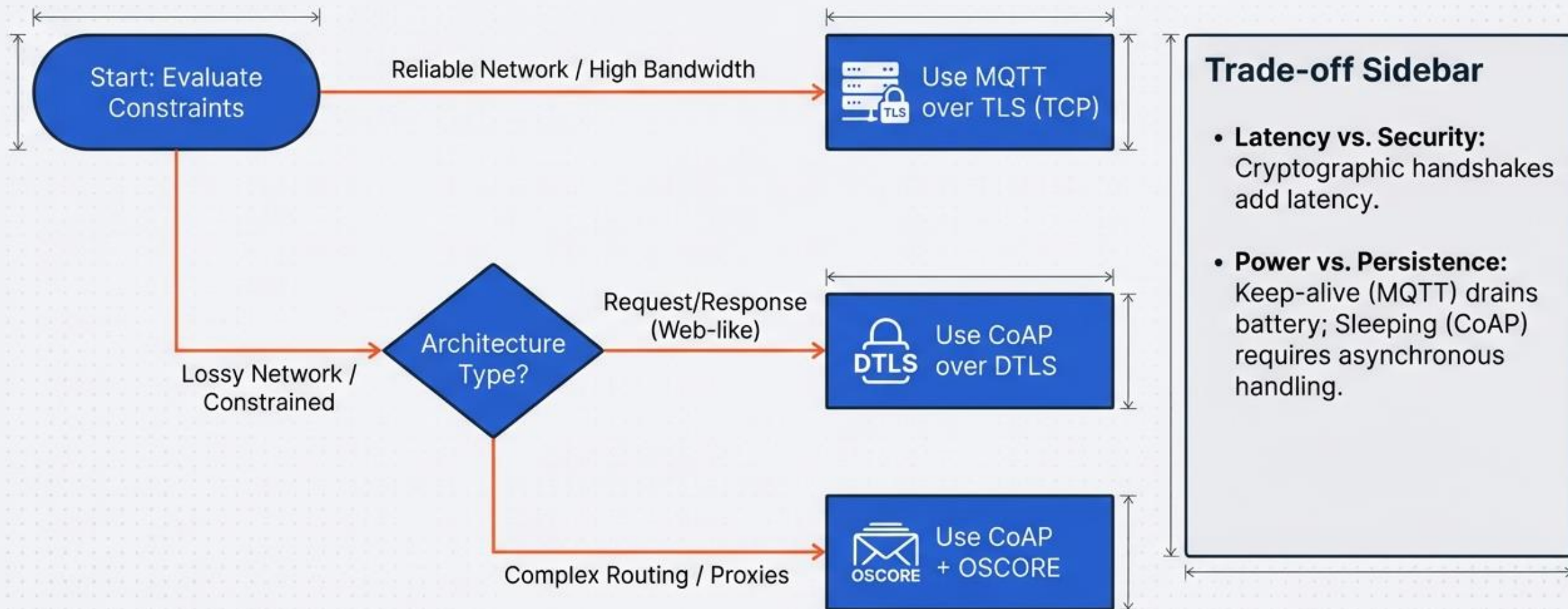
Critical Thinking Questions

- What is the weakest point in the MQTT architecture?
- How would you secure low-cost IoT devices?
- Should security be implemented at device or broker?
- What trade-offs exist between cost and protection?

Learning Objectives Reinforcement

- Connect theory to real deployment challenges
- Encourage architectural reasoning
- Highlight engineering decision trade-offs
- Prepare for advanced IoT security topics

Engineering Decision Matrix: Selecting the Right Protocol



Identity and Authentication for IoT Devices



Credential Approaches

- X.509 certificate-based authentication
- Pre-shared key (PSK) authentication
- Token-based authentication (JWT)
- OAuth-based delegated authorisation

Engineering Trade-offs

- Certificate management complexity at scale
- PSK simplicity vs security limitations
- Token expiration and renewal challenges
- Manufacturing and provisioning considerations

Authorisation Models in IoT Systems



Access Control Mechanisms

- Role-based access control (RBAC)
- Attribute-based access control (ABAC)
- Capability-based authorisation tokens
- Broker-level permissions in messaging systems

Security Considerations

- Principle of least privilege enforcement
- Dynamic policy updates across devices
- Separation between authentication and authorisation
- Policy management complexity at scale

Cryptographic Requirements

- Confidentiality, integrity, and authenticity
- Lightweight computation requirements
- Minimal memory footprint
- Energy-efficient operations

Algorithm Choices

- Symmetric encryption for efficiency
- Elliptic curve cryptography for key exchange
- Authenticated encryption with associated data (AEAD)
- Lightweight cryptography standards (e.g., Ascon)

Lifecycle of Cryptographic Keys

- Secure key generation and provisioning
- Storage in secure hardware or memory
- Key rotation and renewal mechanisms
- Revocation after compromise

Deployment Challenges

- Manufacturing supply chain integration
- Secure onboarding of devices to networks
- Handling lost or compromised devices
- Scaling key management to millions of devices

Part IV — Hardware Roots of Trust and Lifecycle Security

IoT Security: From Hardware Foundations to Secure Deployment

THE HARDWARE FOUNDATION (Roots of Trust)



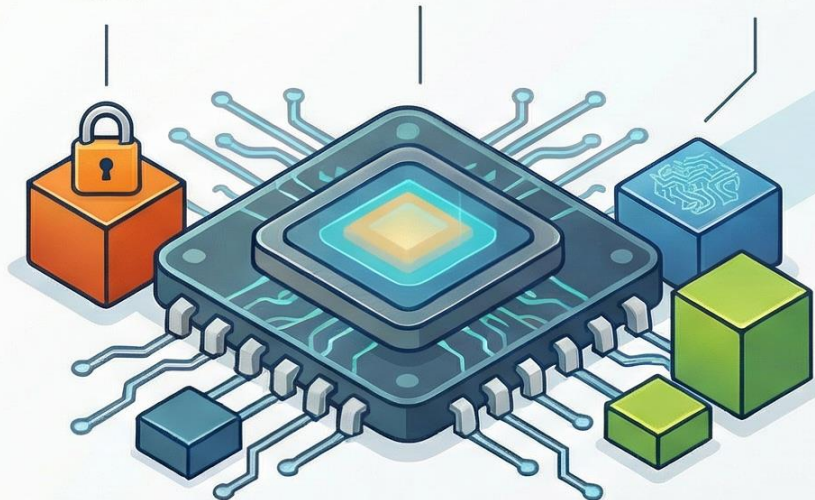
Hardware Root of Trust (RoT)
Secure storage for cryptographic keys; acts as a verification anchor.



Secure Boot & Chain of Trust
Immutable Boot ROM verifies bootloader, then firmware, ensuring only trusted code executes.



Physical Unclonable Functions (PUF)
Uses unique manufacturing variations to create a device "fingerprint" for secure key generation without storing secrets.



LIFECYCLE & COMMUNICATION SECURITY



End-to-End Lifecycle Management

Security spans from secure provisioning during manufacturing to secure data wiping at decommissioning.

Hardened MQTT Architecture



Secure OTA Firmware Updates

Uses digital signatures and version control to prevent malicious code injection and rollback attacks during updates.

Hardware Root of Trust Concepts



Definition and Purpose

- Hardware-based foundation for system trust
- Secure storage of cryptographic keys and secrets
- Verification anchor for software integrity
- Protection against software-level compromise

Security Benefits

- Prevents unauthorised firmware execution
- Protects device identity credentials
- Enables secure boot processes
- Provides tamper-resistant protection

Trusted Hardware Technologies



Trusted Execution Environments (TEE)

- Isolated secure execution regions within processors
- Separation between secure and normal worlds
- Protection of sensitive operations and data
- Widely used in embedded processors (e.g., ARM TrustZone concepts)

Secure Elements and TPM

- Dedicated hardware chips for secure key storage
- Cryptographic operations performed inside hardware
- Resistance to physical extraction attacks
- Used in industrial and high-security devices

PUF Principles

- Unique hardware characteristics from manufacturing variation
- Device-specific fingerprint generation
- No need to store secret keys explicitly
- Resistance to cloning attacks

Applications in IoT Security

- Device authentication and identification
- Secure key generation and storage
- Anti-counterfeiting protection
- Supply chain security validation

Secure Boot Fundamentals



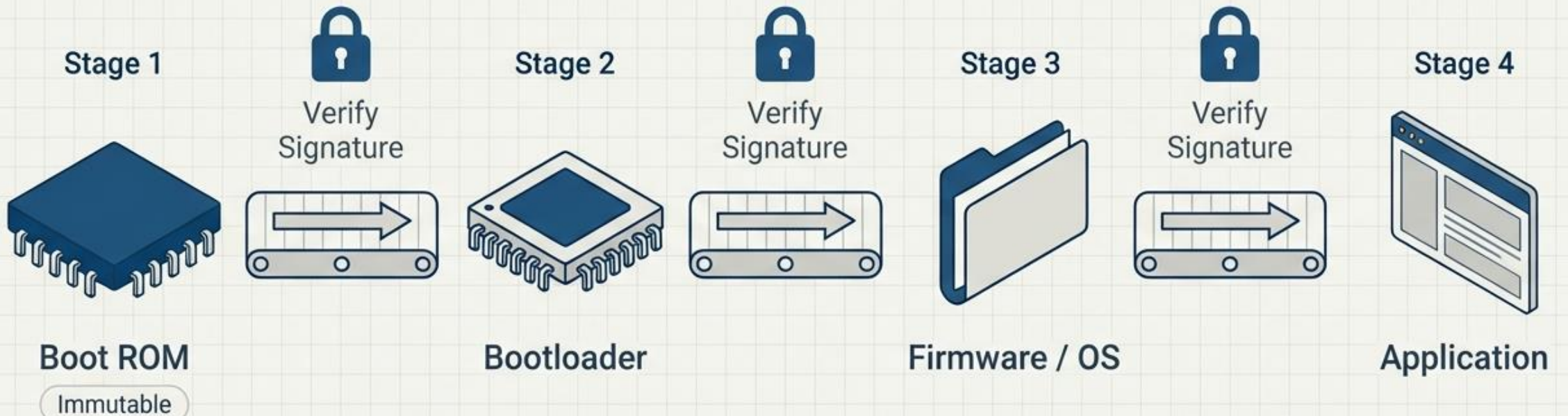
Secure Boot Objectives

- Ensure only trusted firmware executes
- Prevent malicious code injection
- Maintain system integrity from power-on
- Establish chain of trust across software layers

Boot Verification Process

- Boot ROM verifies bootloader signature
- Bootloader verifies firmware integrity
- Firmware verifies application code
- Cryptographic signatures enforce authenticity

SECURE BOOT: THE RELAY RACE OF TRUST



Logic Tree

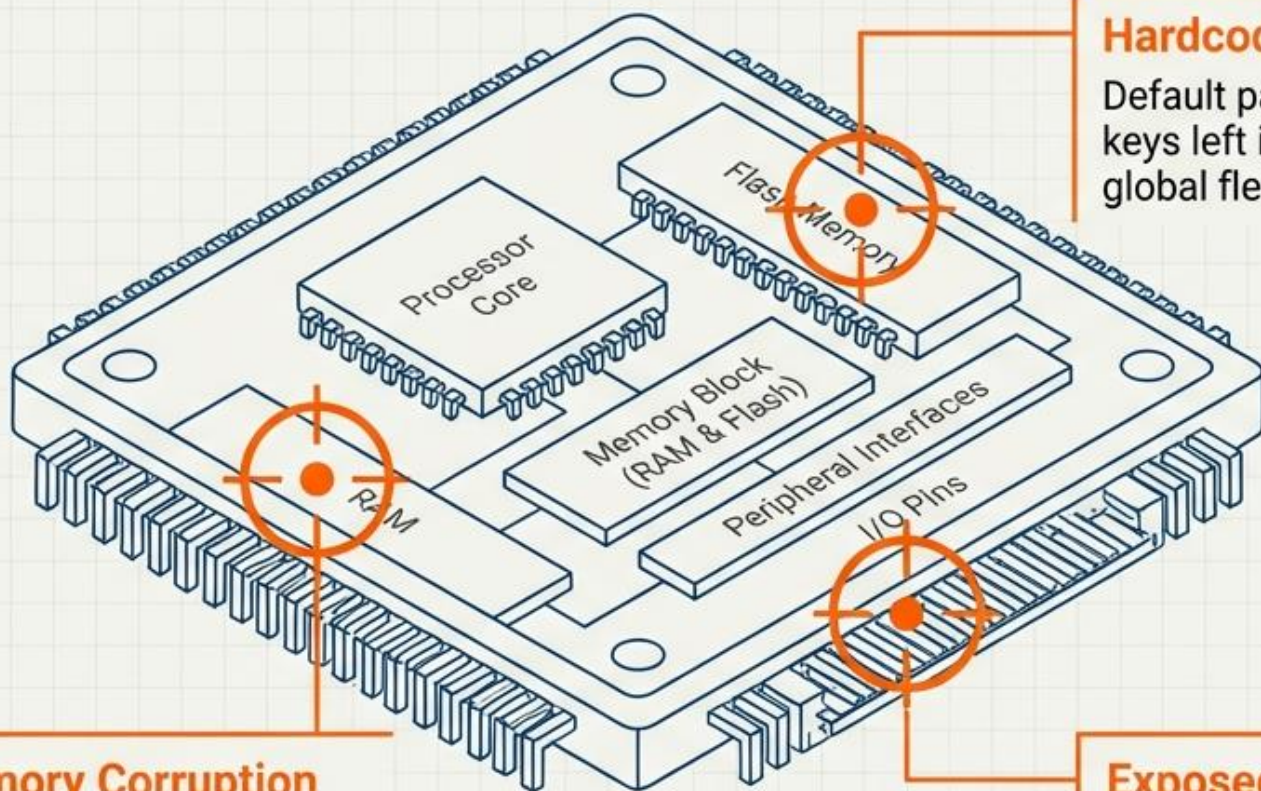


If Verification = **SUCCESS** ->
Pass baton to next stage.



If Verification = **FAIL** -> **SYSTEM HALT**.
(Prevents **malware execution**).

THE FIRMWARE ATTACK SURFACE



Hardcoded Credentials

Default passwords or API keys left in the code allow global fleet compromise.

Memory Corruption

Buffer overflows in the firmware logic can lead to remote code execution.

Exposed Debug Ports

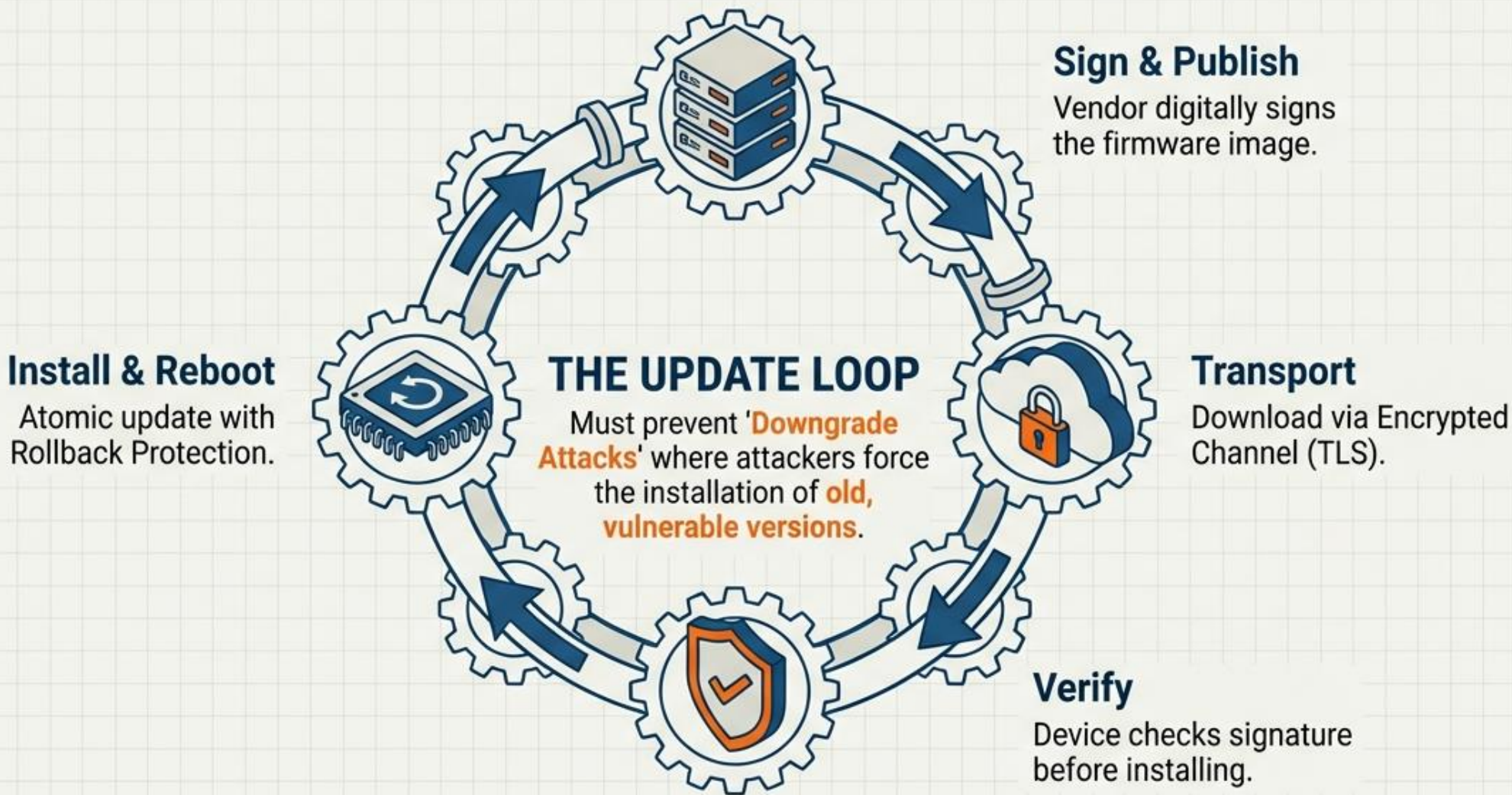
JTAG/UART interfaces left open after manufacturing allow attackers to dump memory.



Consequences:

Devices can be bricked, recruited into botnets (Mirai), or used to pivot into the local network.

SECURE OTA: PATCHING WITHOUT PERIL



LIFECYCLE SECURITY

From Birth to Decommissioning



BIRTH

(Manufacturing)

Secure Provisioning
Injection of unique keys
into the Secure Element.
Supply chain validation.



LIFE

(Operation)

Maintenance
Regular OTA patches and
anomaly monitoring.



DEATH

(Decommissioning)

Secure Disposal
Cryptographic erasure of
all keys and data to
prevent residual leakage.



**Risk of Data
Leakage**

Summary and Looking Ahead



IoT security is fundamentally different from traditional IT security



Security must be considered across the entire IoT stack



Strong identity, authentication, and access control are foundational



Hardware trust and lifecycle management determine long-term security



Engineering trade-offs are unavoidable in IoT deployments

Week 7: Open Research Problems in IoT; Presentation and Exam Preparation!

References

- [1] I. Butun, P. Österberg and H. Song, "Security of the Internet of Things: Vulnerabilities, Attacks, and Countermeasures," in *IEEE Communications Surveys & Tutorials*, vol. 22, no. 1, pp. 616-644, Firstquarter 2020
- [2] Object Security for Constrained RESTful Environments (OSCORE), <https://www.rfc-editor.org/rfc/pdf/rfc8613.txt.pdf>

Some graphics/slides are generated by NotebookLM with provided sources!